Supplier Security and Privacy Assurance (SSPA) program

> **Important**
>
> If there's a conflict between the information in this article and the SSPA page, the SSPA page takes precedence. For the most up-to-date information, see here .

Microsoft believes that privacy is a fundamental right. In the mission to empower every individual and organization on the planet to achieve more, Microsoft strives to earn and maintain the trust of its customers.

Strong privacy and security practices are critical to this mission, essential to trust, and in several jurisdictions required by law. The standards captured in Microsoft's privacy and security policies reflect our values as a company and extend to suppliers that process Personal and Confidential Data on our behalf.

The Supplier Security and Privacy Assurance (SSPA) Program delivers Microsoft's baseline data processing instructions to suppliers in the form of the Microsoft Supplier Data Protection Requirements (DPR).

> **Note**
>
> Suppliers might need to meet additional organizational level requirements that Microsoft groups responsible for the engagement with the supplier decide and communicate outside of SSPA.

SSPA program overview

SSPA is a partnership between Microsoft Procurement, Corporate External and Legal Affairs, and Corporate Security to ensure privacy and security principles are followed by suppliers. The scope of SSPA covers all suppliers globally that process Personal Data and/or Microsoft Confidential Data.

SSPA enables the supplier to make Data Processing Profile selections that align with the goods and/or services suppliers are contracted to perform. These selections trigger corresponding requirements to provide compliance assurances.

All enrolled suppliers must complete an annual self-attestation of DPR compliance. A supplier's Data Processing Profile determines whether the full DPR is issued or if a subset of requirements applies. Suppliers that process data that Microsoft considers higher risk might also need to meet extra requirements, such as providing independent verification of compliance. Suppliers that are on a published Microsoft subprocessor list must also provide independent verification of compliance.

SSPA scope

All suppliers globally that process Personal or Microsoft Confidential Data under their contract with Microsoft must comply with the SSPA program. The DPR contains a section called Definitions where you can find definitions and examples for each of these data categories.

Data Processing Profile

Microsoft suppliers control their SSPA Data Processing Profile. They decide which engagements they want to be eligible to perform.

Microsoft business groups can only create engagements with suppliers when the data processing activity matches the approvals the supplier obtained.

Suppliers can update their Data Processing Profile at any time during the year if there are no open tasks. When a change is made, the corresponding activity is issued and must be completed before the approvals are secured. The existing, completed approvals apply until newly issued requirements are completed.

If the newly executed tasks aren't completed within the 90-day time frame allowed, the SSPA status updates to Red (noncompliant), and the account is deactivated from Microsoft Accounts Payable systems.

Assurance requirements

The approvals selected in the supplier's Data Processing Profile help SSPA assess the risk level across the supplier's engagements. SSPA compliance requirements differ based on the Data Processing Profile and associated approvals.

Some combinations of approvals elevate or reduce compliance requirements. The combinations are captured in the Requirements based on profile approvals section.

If the supplier's profile includes Software as a Service (SaaS), subcontractors, website hosting, or payment cards, additional assurances are required.

Self-attestation to the DPR

All suppliers enrolled in SSPA must complete a self-attestation of compliance with the DPR within 90 days of receiving the request. This request must be provided annually but can be more frequent if the Data Processing Profile is updated mid-year. Supplier accounts change to an SSPA status of Red (noncompliant) if the 90-day period is exceeded. New in-scope purchase orders can't process until the SSPA status turns to Green (compliant).

Newly enrolled suppliers must complete issued requirements to secure an SSPA status of Green (compliant) before engagements can begin.

Applicability

Suppliers are expected to respond to all applicable DPR requirements issued per the Data Processing Profile. Some issued requirements might not apply to the goods or services the supplier provides to Microsoft. Suppliers can mark these requirements as 'doesn't apply' with a detailed comment for SSPA reviewers to validate.

The SSPA team reviews DPR submissions for any selections of 'doesn't apply', 'local legal conflict', or 'contractual conflict' against issued requirements.

Independent assessment requirement

If the supplier has a Data Processing Role of *Subprocessor*, they must have an independent assessment conducted annually.

The **Requirements based on profile approvals** section includes acceptable certification alternatives if you elect not to use an independent assessor to verify compliance with the DPR (when applicable, such as for SaaS suppliers, website hosting suppliers, or suppliers with Subcontractors). The ISO 27701 (privacy) and ISO 27001 (security) provide close mapping to the DPR.

If a supplier is a healthcare provider in the United States or covered entity, Microsoft accepts a HITRUST report for privacy and security coverage.

SSPA might execute an independent assessment manually if circumstances beyond standard triggers warrant additional due diligence. Examples include a request from division privacy or security, validation of data incident remediation, or requirement for automated data subject rights execution.

PCI DSS certification requirement

If a supplier handles payment card information on Microsoft's behalf, they must provide evidence of adherence to the Payment Card Industry Data Security Standard (PCI DSS).

Depending on the volume of transactions processed, a supplier either needs a Qualified Security Assessor to certify compliance or can complete a self-assessment questionnaire form.

Payment card brands set the thresholds for assessment type, typically:

- Level 1: Provide a Third Party Assessor PCI AOC certificate
- Level 2 or 3: Provide a PCI DSS Self-Assessment Questionnaire (SAQ) signed by the supplier's officer.

Software as a Service requirement

Suppliers that meet the SaaS definition included on the Data Processing Profile might need to provide a valid ISO 27001 certification.

Use of subcontractors

Microsoft considers the use of subcontractors a high-risk factor. Suppliers who use subcontractors to process Personal and Microsoft Confidential Data must disclose those subcontractors. Additionally, the supplier should disclose the countries or regions where each subcontractor processes personal data.

Resources

- Supplier Security & Privacy Assurance | Microsoft Procurement
- Microsoft Online Services Subprocessors List

Last updated on 09/29/2025